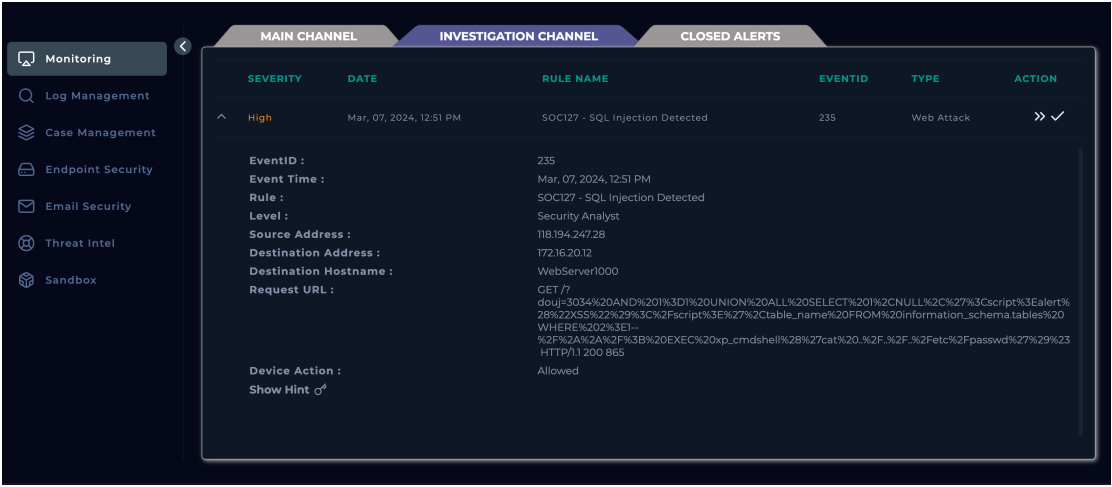


Official Incident Report: SOC127 - SQL Injection Detected

1. Incident Overview

- **Event ID:** 235
- **Rule Name:** SOC127 - SQL Injection Detected
- **Event Time:** Mar, 07, 2024, 12:51 PM
- **Source IP:** 118.194.247.28
- **Destination IP & Hostname:** 172.16.20.12 (WebServer1000)
- **Device Action:** Allowed
- **Verdict:** True Positive



The screenshot shows a security monitoring interface with a sidebar on the left containing 'Monitoring', 'Log Management', 'Case Management', 'Endpoint Security', 'Email Security', 'Threat Intel', and 'Sandbox'. The main area has three tabs: 'MAIN CHANNEL', 'INVESTIGATION CHANNEL' (selected), and 'CLOSED ALERTS'. Below the tabs is a table with columns: SEVERITY, DATE, RULE NAME, EVENTID, TYPE, and ACTION. A single row is visible with a 'High' severity event on 'Mar, 07, 2024, 12:51 PM' for the rule 'SOC127 - SQL Injection Detected' with event ID '235' and type 'Web Attack'. An expandable view shows detailed event information.

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	ACTION
High	Mar, 07, 2024, 12:51 PM	SOC127 - SQL Injection Detected	235	Web Attack	>> ✓
EventID : 235 Event Time : Mar, 07, 2024, 12:51 PM Rule : SOC127 - SQL Injection Detected Level : Security Analyst Source Address : 118.194.247.28 Destination Address : 172.16.20.12 Destination Hostname : WebServer1000 Request URL : GET /? douj=3034%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%22XS%22%29%3C%2Fscript%3E%27%2Ctable_name%20FROM%20information_schema.tables%20WHERE%202%3E1%2F%2A%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20.%2F.%2F.%2Fetc%2Fpasswd%27%29%23 HTTP/1.1 200 865 Device Action : Allowed Show Hint ⚙					

2. Log & Traffic Analysis Through the Log Management interface, a search for the attacker's IP revealed a highly aggressive interaction with the network:

- **Pre-Attack Reconnaissance:** A total of 42 events were logged originating from the source IP immediately prior to the alert. The logs indicate requests sent to various destination ports (e.g., 44023, 47513, 19078), confirming that the attacker initiated an active port scan to identify open services before launching the targeted web attack.

Monitoring

Log Management

Case Management

Endpoint Security

Email Security

Threat Intel

Sandbox

New Search

Source Address contains "118.194.247.28"

All Time

42 events (before Mar, 07, 2024, 12:53 PM UTC)

1 2 3 4 5

Hide Fields

INTERESTING FIELDS

type

source_address

source_port

destination_address

destination_port

raw_log

Event

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=44023 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=47513 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=48751 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=34508 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=19078 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=48750 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=47056 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

- **Malicious HTTP Request:** At 12:51 PM, a GET request targeting port 80 was captured by the proxy. The Raw Data reveals an HTTP response code of 200 (OK) with a response size of 865 bytes, and explicitly exposes the User-Agent as `sqlmap/1.7.2#stable`.

Monitoring

Log Management

Case Management

Endpoint Security

Email Security

Threat Intel

Sandbox

New Search

Source Address contains "118.194.247.28"

All Time

42 events (before Mar, 07, 2024, 12:53 PM UTC)

1 2 3 4 5

Hide Fields

INTERESTING FIELDS

type

source_address

source_port

destination_address

destination_port

raw_log

Event

[Mar, 07, 2024, 12:51 PM] source_address=118.194.247.28 source_port=27086 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:50 PM] source_address=118.194.247.28 source_port=29078 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

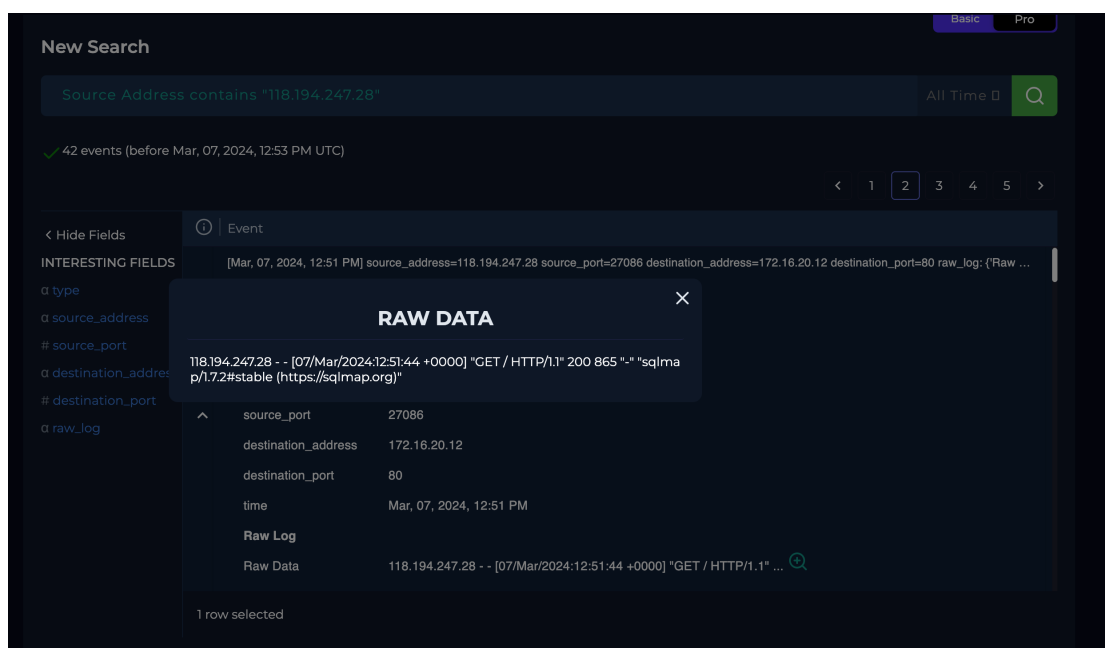
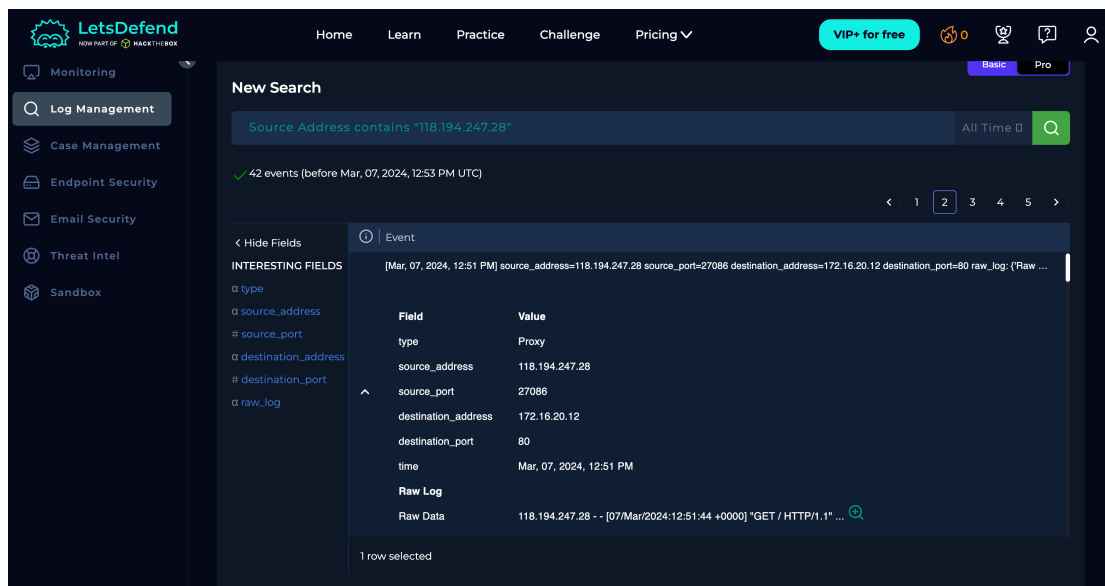
[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=45026 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=44023 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=47052 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=27860 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...

[Mar, 07, 2024, 12:53 PM] source_address=118.194.247.28 source_port=38751 destination_address=172.16.20.12 destination_port=80 raw_log: {'Raw ...



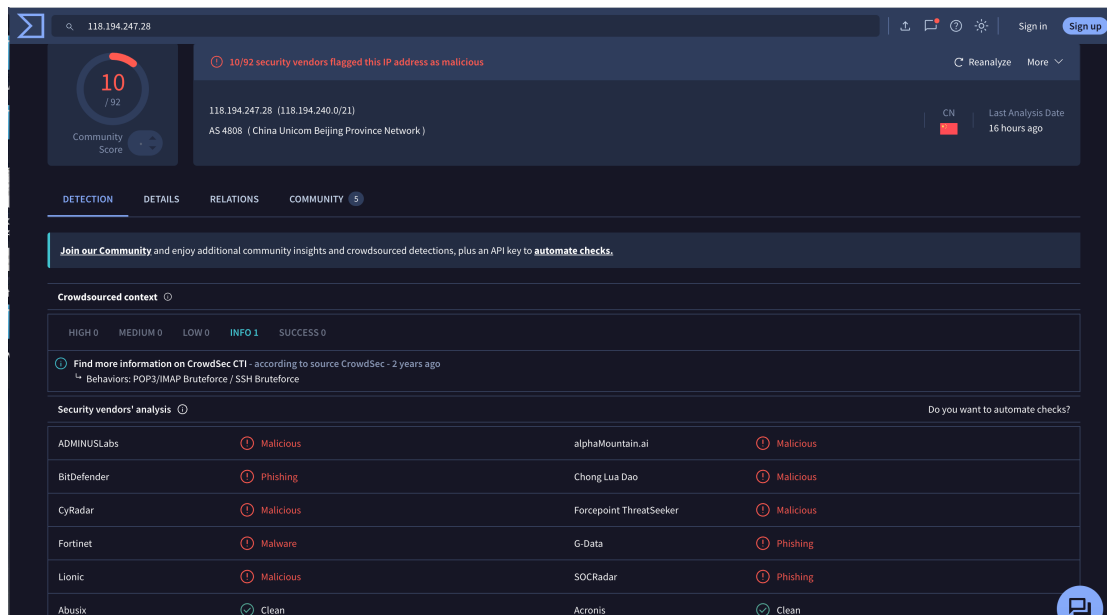
3. Payload Mechanics & Attack Vectors The captured URL parameter (/?douj=...) was decoded and analyzed. The single payload is a sophisticated multi-vector attack containing several distinct malicious layers:

- **SQL Injection (Testing):** The inclusion of AND 1=1 is a classic boolean-based testing technique designed to always evaluate as true, allowing the attacker to map the query structure.
- **Data Exfiltration (UNION Query):** The payload utilizes UNION ALL SELECT to append malicious output to legitimate database responses, specifically attempting to dump database schemas by querying information_schema.tables.

- **Cross-Site Scripting (XSS):** The payload injects '`<script>alert("XSS")</script>`' directly into the database query, testing if the application improperly reflects database inputs back to the front-end interface.
- **Remote Code Execution (RCE):** The most critical segment of the payload is `EXEC xp_cmdshell('cat ../../etc/passwd')`. This attempts to leverage a high-privilege SQL server function to execute OS-level commands and exfiltrate the Linux system's password file, which would lead to total system compromise.
- **Evasion:** SQL comments (`--` and `//`) are utilized to obfuscate the payload, bypass simple WAF filters, and terminate the original legitimate query early.

4. Threat Intelligence (OSINT) External intelligence corroborates the historical malicious nature of the source IP:

- **VirusTotal:** 10 out of 92 security vendors flag the IP 118.194.247.28 (AS 4808 - China Unicom Beijing Province Network) as Malicious.



The screenshot shows the VirusTotal interface for the IP address 118.194.247.28. The top section displays a 'Community Score' of 10/92, indicating that 10 out of 92 security vendors have flagged this IP as malicious. Below this, the IP is identified as belonging to AS 4808 (China Unicom Beijing Province Network). The interface includes tabs for 'DETECTION', 'DETAILS', 'RELATIONS', and 'COMMUNITY'. The 'DETECTION' tab is active, showing a 'Crowdsourced context' section with a link to 'Find more information on CrowdSec CTI' and a 'Security vendors' analysis' table. The table lists 10 vendors and their respective classifications for the IP.

Security vendors' analysis			
ADMINUSLabs	Malicious	alphaMountain.ai	Malicious
BitDefender	Phishing	Chong Lua Dao	Malicious
CyRadar	Malicious	Forcepoint.ThreatSeeker	Malicious
Fortinet	Malware	G-Data	Phishing
Lionic	Malicious	SOCradar	Phishing
Abusix	Clean	Acronis	Clean

AbuseIPDB Anomaly Analysis: A query on AbuseIPDB reveals over **4,304 historical reports** of abusive behavior from this IP. Although the current "Confidence of Abuse" sits at 0%, this is a typical artifact of the platform's time-decay algorithm (indicating the IP hasn't been active in recent weeks). The massive volume of historical reports definitively confirms its status as a known malicious scanner/botnet node at the time of the incident.

AbuseIPDB » [118.194.247.28](#)

Check an IP Address, Domain Name, Subnet, or ASN
e.g. 175.139.66.127, microsoft.com, 5.188.10.0/24, or AS15169

175.139.66.127 [CHECK](#)

118.194.247.28 was found in our database!

This IP was reported **4,304** times. Confidence of Abuse is **0%**: ?

0%

ISP	Beijing CNISP Technology Co., Ltd.
Usage Type	Fixed Line ISP
ASN	AS4808
Domain Name	cnisp.org.cn
Country	China
City	Beijing, Beijing

IP info including ISP, Usage Type, and Location provided by [IPInfo](#). Updated weekly.

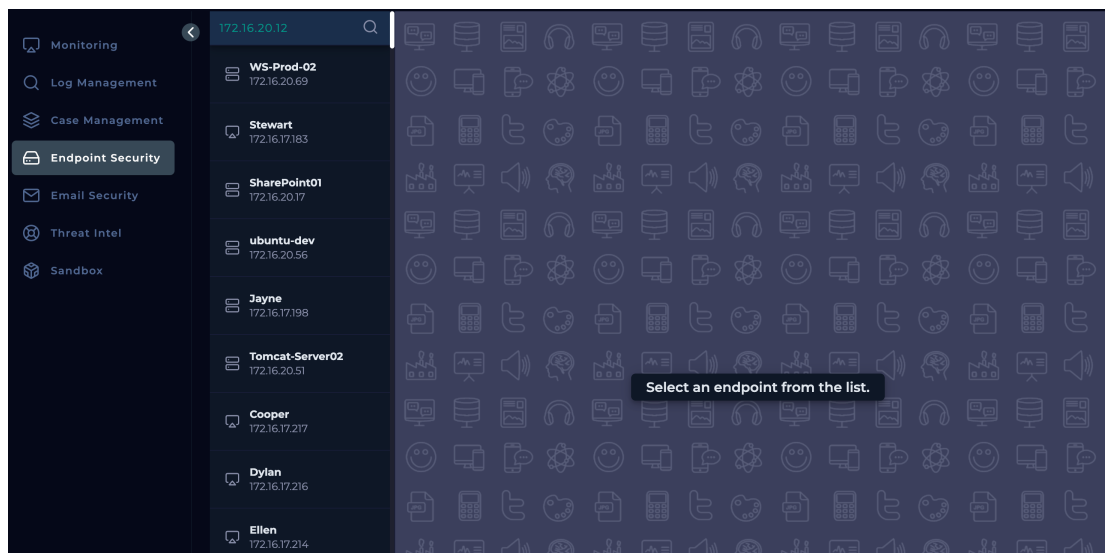
[REPORT 118.194.247.28](#) [WHOIS 118.194.247.28](#)

[ADS VIA CARBON](#)

IP Abuse Reports for **118.194.247.28**:

5. Containment Limitations & Critical Caveats

- **Endpoint Visibility Gap:** I attempted to locate 172.16.20.12 in the Endpoint Security module to analyze running processes or isolate the machine, but the host was missing from the platform's EDR registry.



- **Status Code Misconception:** While the Proxy logs show an HTTP 200 OK, this *only* indicates that the web server successfully processed the HTTP request. It does **not** confirm that the SQL injection or the xp_cmdshell execution was successful at the database layer. Database audit logs would be required to verify if the data was actually dumped.

6. MITRE ATT&CK Mapping

- **Reconnaissance:** Active Scanning: Vulnerability Scanning
- **Initial Access:** Exploit Public-Facing Application
- **Credential Access:** Unsecured Credentials: Credentials In Files

7. Remediation Strategy

1. **Disable High-Risk Functions:** Immediately disable xp_cmdshell in the database configuration, as it provides a direct bridge from the database to the underlying operating system.
2. **WAF Hardening:** Implement Web Application Firewall (WAF) rules to strictly block requests containing default penetration testing tool User-Agents (e.g., sqlmap).
3. **Input Sanitization:** Refactor the vulnerable web application to utilize Parameterized Queries (Prepared Statements) to neutralize all SQL injection vectors at the code level.

